

DCST1005 – Digital infrastruktur og cybersikkerhet

Mock Eksamen 1

Tid: 3 timer

Hjelpemidler: Ingen

Totalt antall poeng: 100

Denne øvingseksamen er utformet for å gi deg trening i eksamensformat og pensum. MERK! Det kan være noen spørsmål som er litt på siden av pensum/hva vi har vært igjennom i praktiske øvinger i faget. Formålet er både å trene på eksamensformat og flette inn pensum.

Del A – Flervalg (12 spørsmål, 1 poeng hver = 12 poeng)

Velg ett svar per spørsmål.

1. Hva er en domenekontroller (Domain Controller) i et Windows Server-miljø?
 - a) En server som kun håndterer DNS-oppslag for klienter i nettverket
 - b) En server som kjører Active Directory Domain Services og håndterer autentisering og katalogtjenester for domenet
 - c) En dedikert brannmurserver som kontrollerer trafikk inn og ut av domenet
 - d) En server som distribuerer programvare til klienter via Group Policy
2. Hva er forskjellen mellom en universell gruppe og en global gruppe i Active Directory?
 - a) Universelle grupper kan kun brukes innenfor ett domene, globale grupper kan brukes på tvers av domener
 - b) Globale grupper kan kun inneholde brukere fra samme domene, mens universelle grupper kan ha medlemmer fra hele skogen
 - c) Det er ingen forskjell – begge fungerer likt i et enkeltdomene-miljø
 - d) Universelle grupper brukes kun til e-postdistribusjon, globale grupper til tilgangsstyring
3. Hva skjer med en brukers GPO-innstillinger dersom en GPO på OU-nivå og en GPO på domeninivå har motstridende innstillinger for samme policy?
 - a) Domenepolicyen vinner alltid, uavhengig av OU-innstillingene
 - b) OU-policyen vinner, fordi den er nærmere brukerobjektet i hierarkiet og har høyere prioritet

- c) Begge GPO-ene ignoreres og standardinnstillingen benyttes
 - d) Resultatet er uforutsigbart og avhenger av hvilken GPO ble opprettet først
-

4. Hvilken kommando kjøres på en klientmaskin for å tvinge en umiddelbar oppdatering av Group Policy?

- a) `gpresult /force`
 - b) `gpupdate /force`
 - c) `gpedit /refresh`
 - d) `Invoke-GPUdate /now`
-

5. Hva er formålet med AGDLP-prinsippet i Active Directory?

- a) En fremgangsmåte for å sikkerhetskopiere AD-databasen på en strukturert måte
 - b) En navnekonvensjon for OU-er i store organisasjoner
 - c) En anbefalt metode for å strukturere tilgangsstyring ved å neste grupper i hverandre på en bestemt måte
 - d) Et prinsipp for å delegere administratorrettigheter til helpdesk-ansatte
-

6. En administrator ønsker at alle servere i domenet automatisk låser skjermen etter 10 minutter uten aktivitet. Hvilken type GPO-innstilling brukes?

- a) User Configuration, fordi det gjelder brukerens økt
 - b) Computer Configuration, fordi innstillingen skal gjelde maskinen uavhengig av hvem som er logget på
 - c) Begge deler må konfigureres for at innstillingen skal virke
 - d) Dette kan ikke styres via GPO og må konfigureres manuelt på hver server
-

7. Hva er en ressursgruppe i Azure?

- a) En type virtuell maskin optimalisert for ressurskrevende arbeidsbelastninger
 - b) En logisk beholder som grupperer relaterte Azure-ressurser slik at de kan administreres samlet
 - c) Et Azure-verktøy for å overvåke CPU- og minnebruk på tvers av abonnementer
 - d) En sikkerhetspolicy som begrenser hvilke ressurstyper som kan opprettes i et abonnement
-

8. Hva er forskjellen mellom inngående (inbound) og utgående (outbound) regler i en NSG?

- a) Inngående regler kontrollerer trafikk som forlater en ressurs, utgående regler kontrollerer trafikk som ankommer

- b) Inngående regler kontrollerer trafikk som ankommer en ressurs, utgående regler kontrollerer trafikk som forlater
 - c) Det er ingen funksjonell forskjell – begge regeltyper behandles likt av Azure
 - d) Utgående regler gjelder kun for trafikk mot internett, inngående regler gjelder kun intern VNet-trafikk
-

9. Hvilken Azure-tjeneste brukes for å gi on-premises servere Azure-administrasjonsfunksjoner uten å flytte dem til skyen?

- a) Azure Migrate
 - b) Azure Arc
 - c) Azure Site Recovery
 - d) Azure Bastion
-

10. Hva er «scope» i Azure RBAC-sammenheng?

- a) Navnet på rollen som tildeles en bruker eller tjeneste
 - b) Det nivået i Azure-hierarkiet (abonnement, ressursgruppe eller ressurs) som en rolletildeling gjelder for
 - c) En liste over hvilke IP-adresser som har tilgang til en ressurs
 - d) En policy som begrenser hvilke Azure-regioner ressurser kan opprettes i
-

11. Hva er hensikten med et dedikert administrasjonssubnett i en hub-spoke topologi?

- a) Å redusere kostnader ved å samle alle ressurser i færrest mulig subnett
 - b) Å isolere administrasjonsverktøy og tilgangsressurser fra ordinær arbeidslasttrafikk, slik at administrasjonstrafikk kan sikres og overvåkes separat
 - c) Å sikre at Azure Firewall alltid er plassert i samme subnett som de virtuelle maskinene den beskytter
 - d) Azure krever et eget administrasjonssubnett for at VNet Peering skal fungere
-

12. Hva er en parameter i PowerShell, og hva er fordelen med å bruke parametere fremfor hardkodede verdier i et script?

- a) En parameter er et fast definert variabelnavn som alltid starter med `$_`
 - b) En parameter er en verdi som sendes inn til scriptet ved kjøring, noe som gjør scriptet gjenbrukbart uten å måtte endre koden
 - c) Parametere brukes kun i funksjoner, ikke i frittstående scripts
 - d) En parameter er det samme som en variabel og har ingen spesiell funksjon utover navngiving
-

Del B – Windows Server og on-premises administrasjon (30 poeng)

Kontekst: InfracT.sec har fått en ny avdeling kalt **Prosjekt**, og selskapet ønsker at alle ansatte i denne avdelingen skal ha tilgang til en felles prosjektmappe på filserveren **SRV1**. I tillegg skal IT-avdelingen rydde opp i eksisterende brukerkontoer og GPO-struktur.

Oppgave B1 – Brukere og tilgangsstyring (15 poeng)

- a) Beskriv hvilke steg du utfører for å klargjøre AD-miljøet for den nye Prosjekt-avdelingen. Dette inkluderer opprettelse av nødvendige objekter i AD og hvordan du strukturerer tilgang til prosjektmappen på **SRV1**. Begrunn strukturvalgene dine. (6 poeng)
 - b) IT-avdelingen mistenker at flere gamle brukerkontoer ikke har vært i bruk på over 90 dager. Forklar hvordan du ville identifisert og håndtert disse kontoene på en sikker og sporbar måte. Hva er risikoen ved å la inaktive kontoer forbli aktive i AD? (5 poeng)
 - c) En helpdesk-ansatt trenger mulighet til å tilbakestille passord for brukere i Prosjekt-OU-en, men skal ikke ha administratorrettigheter utover dette. Forklar hvordan du ville løst dette i Active Directory. (4 poeng)
-

Oppgave B2 – Group Policy (15 poeng)

- a) IT-ledelsen ønsker at alle bærbar PC-er i selskapet skal krypteres med BitLocker, og at krypteringsnøkklene skal lagres i Active Directory. Beskriv hvordan du ville brukt GPO til å konfigurere og håndheve dette kravet. (5 poeng)
 - b) En GPO er konfigurert på domenivå for å deaktivere USB-lagring på alle maskiner. IT-drift-avdelingen trenger likevel å kunne bruke USB-enheter. Beskriv to ulike måter å løse dette på ved hjelp av GPO-mekanismer, og forklar fordeler og ulemper med hver tilnærming. (6 poeng)
 - c) Forklar hva «loopback processing» er i Group Policy-sammenheng, og gi et eksempel på en situasjon der det er nyttig å aktivere denne innstillingen. (4 poeng) (kanskje litt utenfor pensum, sammenlignet med hva vi har gjort i praktiske øvinger)
-

Del C – Azure og offentlig sky (30 poeng)

Kontekst: InfracT.sec har etablert en hub-spoke arkitektur i Azure. Nå skal selskapet utvide miljøet med bedre sikkerhet og mer kontrollert nettverkstrafikk.

Oppgave C1 – Nettverkssikkerhet (15 poeng)

- a) Forklar hva «defense in depth» betyr i en Azure-nettverkskontekst, og beskriv hvordan en kombinasjon av NSG-er og Azure Firewall kan realisere

dette prinsippet i en hub-spoke topologi. (6 poeng)

b) En virtuell maskin i et spoke-subnett skal kun kommunisere med en bestemt database-VM i samme VNet, og all annen utgående trafikk skal blokkeres.

Beskriv hvilke NSG-regler du ville opprettet for å håndheve dette, og forklar hvordan du ville prioritert reglene. (5 poeng)

c) Forklar hva «stateful» trafikkinspeksjon betyr, og hvorfor dette er relevant når man konfigurerer NSG-regler for toveis kommunikasjon mellom to ressurser. (4 poeng)

Oppgave C2 – Tilgangsstyring og kostnadsbevissthet (15 poeng)

a) En ny medarbeider i InfracT.sec skal ha lesetilgang til alle ressurser i ett bestemt Azure-abonnement, men ikke kunne opprette eller slette noe. Beskriv hvilken innebygd RBAC-rolle som passer, og forklar hvordan du tildeler den på riktig scope. (5 poeng)

b) Forklar hva «Azure Policy» er, og gi et eksempel på hvordan det kan brukes til å håndheve at alle virtuelle maskiner i et abonnement alltid får en bestemt tag (f.eks. Miljø: Produksjon). Hvordan skiller Azure Policy seg fra RBAC? (6 poeng)

c) InfracT.sec oppdager at Azure-kostnadene har økt uventet den siste måneden. Beskriv tre konkrete tiltak du ville undersøkt eller iverksatt for å identifisere og redusere kostnadene. (4 poeng)

Del D – PowerShell og automatisering (26 poeng)

Kontekst: InfracT.sec ønsker å automatisere deaktivering av gamle brukerkontoer i Active Directory. Du har fått i oppgave å skrive et script som kjøres månedlig på DC1 .

En tekstfil (inaktive-brukere.txt) inneholder én SamAccountName per linje for brukere som ikke har logget inn på over 90 dager.

Scriptet skal:

1. Lese inn listen over inaktive brukere
2. Deaktivere hver brukerkonto i AD
3. Flytte brukerkontoen til en egen OU kalt
OU=Deaktivert,OU=InfraIT,DC=infracit,DC=sec
4. Gi et sporbart resultat av hva som skjedde under kjøringen

Oppgave D1 – Pseudokode (26 poeng)

a) Skriv et PowerShell-script i pseudokode som løser oppgaven beskrevet ovenfor. Scriptet skal være robust, håndtere feil på en kontrollert måte, og gi et sporbart resultat av hva som skjedde under kjøringen. (18 poeng)

b) Begrunn kort tre sentrale valg du tok i utformingen av scriptet, og forklar hvorfor disse valgene gjør scriptet bedre egnet for bruk i et produksjonsmiljø.

(8 poeng)

— Lykke til! —